

SUMMER 2024
ISSUE

Gregory Vial
Julien Crowe
Patrick Mesana

Managing Data Privacy Risk in Advanced Analytics

Cybersecurity techniques that keep personal data safe can limit its use for analytics — but data scientists, data owners, and IT can partner more closely to find middle ground.

Managing Data Privacy Risk in Advanced Analytics

Cybersecurity techniques that keep personal data safe can limit its use for analytics — but data scientists, data owners, and IT can partner more closely to find middle ground.

By Gregory Vial, Julien Crowe, and Patrick Mesana

“HOW CAN WE PROTECT THE PRIVACY of our customers’ personal data while leveraging that data via AI and analytics?” This question reflects a growing internal dilemma as companies pursue advanced analytics and artificial intelligence.

The troves of data that customers’ ever-more-digitalized lives produce can be a rich source of insight for organizations using advanced analytics tools. At the same time, this data is a deep source of concern to IT staffs committed to meeting both regulatory agencies’ and consumers’ expectations around data privacy. Both

are important objectives — but meeting them simultaneously requires confronting an inherent conflict. Increasing data privacy in the context of analytics and AI involves using techniques that can reduce the utility of the data, depending on the task and the privacy preservation technique chosen.

The issue is one that an increasing number of organizations will face as the fields of analytics and AI continue to quickly evolve and lead to the widespread availability of an array of tools and techniques (including turn-key and cloud-based services) that enable organizations to put data to work more easily than ever. Meanwhile, customers have increasing expectations that companies

will take all necessary precautions to protect the privacy of their personal data, especially in light of reports of large-scale data breaches covered by mainstream media outlets. Those expectations are backed by regulations on personal data and AI across the globe that make it critical for companies to keep personal data protection practices in compliance.

The Nuances of Protecting Personal Data

Fundamentally, data privacy is about assessing the probability that one or more attributes, or pieces of information, about an individual whose data has been anonymized and included with others in a data set can be used to re-identify that specific individual. Some of these attributes are obvious:



Direct identifiers that enable almost immediate identification include name and Social Security number. *Quasi-identifiers* do not generally enable the identification of a single individual on their own, but their uniqueness or their combination with other attributes may do so. For example, the combination of a person's age and their address may enable their re-identification. Or consider a data set held by a bank's fraud alert team on customers' card transactions. That data set contains both direct identifiers (such as the customer's name) and quasi-identifiers (such as credit card transaction information).

In the context of analytics and AI, quasi-identifiers are often highly valuable because they can help organizations uncover shared characteristics and patterns that may help them better find or serve customers. But even seemingly innocuous quasi-identifiers, such as marital status, can be combined with other pieces of publicly available information to re-identify a specific person. Consequently, companies are already being challenged to go beyond protecting just personally identifiable information and consider how to protect quasi-identifiers as well.

Finding the optimal solutions to the privacy-utility conundrum will also require a broader understanding of data privacy throughout the organization, beyond IT and cybersecurity functions. Managers seeking to better understand the scope of options available in balancing data privacy with utility should be broadly familiar with the array of approaches available. Each has its own advantages and disadvantages, with varying implications for data privacy and data utility. (See "Five Approaches to Preserving Data Privacy.")

Privacy Versus Utility Trade-off

To understand how organizations are confronting the complex matter of protecting personal data in their care while also leveraging it for analytics and AI, we'll look at initiatives recently undertaken at National Bank of Canada. (Note that Julien oversees artificial intelligence at the bank; Gregory and Patrick have studied the organization's practices.) Founded in 1859, National Bank is one of the largest financial institutions in Canada. Like its competitors, it must comply with stringent federal and provincial regulatory requirements. Customers trust that National Bank manages their money and the wealth of personal data they share with the bank (when they execute transactions or apply for loans, for instance) with the utmost care.

As a financial institution, National Bank

considers customer trust to be its greatest asset, and so it has built a culture in which protecting the privacy of its customers' data is a core value. In addition to driving significant efforts and investment in cybersecurity and organizationwide training, it has also increasingly prioritized analytics and AI. Here, new techniques and approaches increase the potential to leverage personal data to improve services for customers. This increasing use of AI techniques also requires heightened protection efforts, given that new approaches can also be used to compromise the privacy of personal data.¹

Data protection had traditionally been treated as a security matter that was the responsibility of cybersecurity experts at National Bank. Under this logic, personal data protection would be guaranteed using tried and proven techniques. However, some of those techniques may not readily achieve the required balance between data privacy and data utility. For example, cybersecurity teams can encrypt entire files, but doing so prevents data scientists from being able to use the data contained within those files. Using a more granular approach, direct identifiers could be protected using tokenization (to achieve de-identification), leaving the data science team able to leverage quasi-identifiers, but this does not address the risk of re-identification associated with those quasi-identifiers. To simultaneously satisfy requirements for both data privacy and data utility, teams must find a common ground that allows them to move beyond techniques that favor an either/or approach. In the case of National Bank, we have identified three important steps that contribute to its ability to achieve this objective.

STEP 1: Bridge the gap between IT and data science. In most organizations, cybersecurity and AI/data science teams don't work together. Each has its specialty, and trying to put data to work requires collaboration between experts who tend to work in silos. National Bank realized that this division led to inefficiencies, frustration, and an overall lack of mutual understanding of teams' respective priorities and concerns, and it set out to mitigate the issue. Managers fostered close collaboration between cybersecurity experts and AI delivery team members — including those in roles such as AI architect, data scientist, machine learning engineer, and data engineer — to evolve their competencies and skill sets in each other's domain of expertise.

One illustration of the importance of building this mutual understanding is the example of using synthetic data, where there may be a probability of

Five Approaches to Preserving Data Privacy

Each approach to preserving the privacy of personal data will have an effect on the degree to which the data set remains useful for AI and analytics.

APPROACH	DESCRIPTION	TYPICAL APPLICATION	TYPICAL USE CASE	SEEN BY REGULATORS AS	IMPACT ON DATA USABILITY
Masking	Hide attribute values in whole or in part with modified characters	Direct identifiers	Credit card numbers, email addresses	De-identification	High (loss of original information)
Tokenization	Replace sensitive attributes with nonsensitive substitutes (tokens)	Direct identifiers	Social Security numbers, bank account numbers	De-identification	High (regain usability through detokenization)
Data anonymization	Remove or modify (for example, swap or generalize) personal information to prevent re-identification	Quasi-identifiers	Health care records, location data	Anonymization	Moderate to low (original properties of the data can be closely approximated)
Data synthesis	Create new data that mimics the properties of the original data set without personal information	Quasi-identifiers	Data science research, data sharing	Anonymization	Low (original properties of the data can be preserved)
Data encryption	Convert data into nonreadable, unstructured text using an algorithm and an encryption key	Entire files	Secure storage and transmission	Anonymization	High (only possible through decryption)

re-identification, depending on the type of algorithm used to generate the data, the data used to train the system, fine-tuning of the parameters, and the attributes to which this approach is applied.² This marks a significant departure from the use of techniques such as data encryption, which provide great security at the expense of any data utility. National Bank’s cybersecurity and AI delivery teams worked together to develop a common understanding of both the issue and the fact that they would have to evaluate the potential for personal data to be de-anonymized against the degree of utility provided by synthetic data. This process gave the cybersecurity team insight into how re-identification techniques are now increasingly rooted in data science, while the AI team improved its understanding of the work that cybersecurity teams do to ensure the proper sharing and use of personal data.

STEP 2: Formalize and document data-privacy decision-making. Decisions regarding data privacy need to be clearly motivated and justifiable to regulators in the eventuality of an audit — a scenario in which

organizations must demonstrate that they have done everything they could to protect the privacy of customer data. That means they must be able to justify why they decided to use a given privacy preservation technique over another in a given situation.

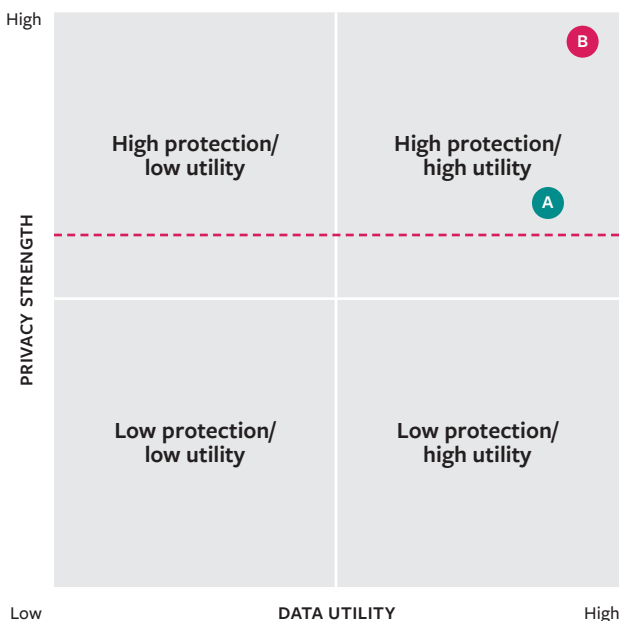
Collaboration between cybersecurity and AI delivery teams at National Bank has led to ongoing efforts to quantify the impacts of various approaches on data privacy and data utility to better inform such decisions. (See “Modeling Data Privacy and Data Utility,” p. 50.) Teams simulate audits on data sets that have been protected using different data privacy approaches and parameters to calculate the probability of re-identification within those data sets. At the same time, they evaluate the utility of those data sets based on the same approaches and parameters. For example, certain data anonymization techniques work by making quasi-identifiers more general (such as substituting broader income brackets for actual income values). While that increases the privacy of customer data, it’s important not to compromise all of the nuances contained in the original data set that make

it valuable for the organization. Using the example of income brackets, those should be neither narrow enough to enable re-identification nor too broad to be useful in analysis. In evaluating these two variables simultaneously, data managers can quantify and document them to make an informed decision in specific data-sharing contexts. The key here is that the combination of data privacy and data utility can be acknowledged as a risk factor that can be mitigated with sufficient confidence.

STEP 3: Keep informed on technology, regulations, and evolving threats. As one might expect, data privacy regulations don't prescribe an approach; they mandate an outcome: keeping people's personal data secure. While regulations may vary across jurisdictions, they generally define criteria that can be applied regardless of the scenario under consideration, such as

Modeling Data Privacy and Data Utility

The figure below is a simplified example of visualizations used at National Bank in deciding on trade-offs between privacy versus utility. Dots A and B represent two different data protection techniques, with dot B predicted to better protect personal data than dot A. The red line represents the baseline compliance with legal requirements for personal data protection.



what constitutes data anonymization. Then organizations are responsible for devising data protection strategies that meet those criteria. Given the rapid advances in de-anonymization practices by bad actors, data privacy is a moving target. Organizations need to understand the risks associated with how they protect data, beyond the bare minimum required by regulation. So it's essential that they proactively stay up to date on not only regulations but tech developments.

One way that National Bank addresses this challenge is by reducing the distance between the legal teams that have visibility into upcoming regulations and the AI teams that work with data. This can happen early on by including legal experts in discussions in which project team members explain their data needs to the internal owners of the data. The data owners are typically connected to the legal team and can bring legal in to discuss how the needs of a particular project fit in with the existing data governance framework at the bank.

The bank also collaborates on multiple projects with universities and academic researchers who specialize in data privacy and security. This gives the bank's relevant teams access to cutting-edge scientific knowledge on recent techniques to support their own research and development while advancing knowledge to incorporate into their practices. Similarly, academic researchers also find collaborations with industry valuable because they often lead to more practical work with real-world impact.

Ramping Up Data Privacy for Data Science Practice

For many companies that are investing in AI and analytics in the hope of gaining valuable business insights from their customer data, the implications for potential exposure of personal data are just emerging. To effectively manage the trade-offs between data privacy and data utility, we suggest the following practices and approaches.

Teach data privacy as part of data literacy. In many organizations, data literacy is still uneven or lacking, and substantial efforts are still required to address this issue.³ In the context of data privacy, this challenge is even more glaring: One cannot assume that managers who possess basic data literacy skills have a clear understanding of data privacy concepts such as direct identifiers and quasi-identifiers. They also need to understand the risks of re-identification associated with these identifiers, and the characteristics of the approaches typically used to address these risks.

In the case of National Bank, data governance and data literacy initiatives have been implemented for several years, and, like many other financial institutions, the bank was an early adopter of analytics and other

Multiple stakeholders must contribute to informed decisions on protecting personal data.

approaches to improve decision-making. However, it has had to further develop data privacy literacy as a competency that transcends specific domains of expertise. Experts working in cybersecurity, legal, and AI delivery all had their own understanding of data privacy, its implications for their department, and the approaches available to mitigate its associated risks. For example, members of one team would use terms referenced in regulations (such as de-identification), while data scientists would consider specific technical approaches to data privacy (such as k-anonymity or differential privacy). Fostering collaboration across functional units has been an important part of developing data privacy literacy at the organizational level.

Treat data privacy as a business issue. Developing data privacy literacy as an organizational capability also supports an organizational culture in which data privacy is treated as a business issue, not a purely technical matter. That is, there should be a widespread understanding that the imperative to manage personal data carefully is founded on the need to maintain customer trust — and is thus directly related to the bottom line. Connecting the dots between personal data protection, company reputation, and performance is possible only if personal data protection is explicitly acknowledged as a strategically relevant matter that requires dedicated time and resources.

Doing this may require a rethink at companies that have relegated data privacy to the cybersecurity team. However, data privacy involves a variety of stakeholders with different expertise and concerns, and they all must be able to communicate in a common language and participate in discussing and designing data privacy strategies.⁴ Cross-disciplinary collaboration is essential — and when something is understood to be a business issue, it is understood as being important to everyone in the organization.

Formalize your approach to balancing data privacy and data utility. As we described above, multiple stakeholders must contribute to informed decisions on how to protect personal data in a given situation. Establishing a systematic approach to working through the issues and communicating the implications of different privacy techniques for data utility and data protection is essential.

National Bank has accomplished this by evaluating

the impact on data privacy and contextualizing it against data utility. That has enabled the creation of tools, such as the matrix presented earlier, that communicate the privacy and utility implications of different conditions in given situations over and above regulatory requirements. With such visualizations, data managers don't need to know the intricacies of data privacy preservation techniques, but they can see their outputs and rely on their data literacy skills to ask pertinent business questions. In addition, computation of quantitative measures can be integrated into the analytics/AI model creation/validation pipeline so that it becomes part of a standard process. This maintains an awareness of the need to continuously improve data privacy approaches as re-identification techniques continue to improve as well.

DATA PRIVACY SHOULD BE AN IMPORTANT area of concern for organizations managing personal data. But it is also a complex business matter that has important technical implications. The quick evolution of the science of data privacy, coupled with modernized regulatory requirements, makes it challenging for companies to optimize their strategies on this front. Ultimately, as data managers gain a deeper understanding of this topic, they can design and evolve strategies that will help them optimize both data privacy and data utility, forgoing the idea that we necessarily need to sacrifice one for the other. ■

Gregory Vial is an associate professor in the Department of Information Technologies at HEC Montréal. **Julien Crowe** is senior director of artificial intelligence at the National Bank of Canada.

Patrick Mesana is a doctoral candidate in the Department of Decision Sciences at HEC Montréal.

REFERENCES

1. C. Dwork, A. Smith, T. Steinke, et al., "Exposed! A Survey of Attacks on Private Data," *Annual Review of Statistics and Its Application* 4 (March 2017): 61-84.
2. T.E. Raghunathan, "Synthetic Data," *Annual Review of Statistics and Its Application* 8 (March 2021): 129-140; and S.L. Garfinkel and C.M. Bowen, "Preserving Privacy While Sharing Data," *MIT Sloan Management Review* 63, no. 4 (summer 2022): 7-10.
3. T.H. Davenport and R. Bean, "Action and Inaction on Data, Analytics, and AI," *MIT Sloan Management Review*, Jan. 19, 2023, <https://sloanreview.mit.edu>.
4. Raghunathan, "Synthetic Data," 129-140; and Garfinkel and Bowen, "Preserving Privacy While Sharing Data," 7-10.

Reprint 65433. For ordering information, see page 4. Copyright © Massachusetts Institute of Technology, 2024. All rights reserved.



PDFs ■ Reprints ■ Permission to Copy ■ Back Issues

Articles published in *MIT Sloan Management Review* are copyrighted by the Massachusetts Institute of Technology unless otherwise specified.

MIT Sloan Management Review articles, permissions, and back issues can be purchased on our website, **shop.sloanreview.mit.edu**.

Reproducing or distributing one or more *MIT Sloan Management Review* articles **requires written permission**.

To request permission, use our website **sloanreview.mit.edu/store/faq** or email **smr-help@mit.edu**.